

RISK MANAGEMENT THE CHRONICLE

Mackenzie Chase

Arthkumar Patel

INTRODUCTION – THE CHRONICLE



The Chronicle

Independent University based
Publication

Trusted source of news for the
community and the city.



Current security Posture

No cybersecurity protection
capabilities



Previously Faced threats

Insider



Scope

Focus on physical and digital
assets.

METHODOLOGY

Framework :
NIST SP 800-30 &
MITRE ATT&CK

Approach :
Qualitative
Approach

Analysis :
Asset/Impact
Oriented based on
their CIA

Threat Analysis :
MITRE ATT&CK

RISK ASSESSMENT – TVA SHEET

Risk ID	Threat ID	Threat Source	Threat Event	Vulnerability	Affected Asset(s)	Risk
R001	T001	Hacktivists	Website defacement to spread misinformation.	Lack of Multi-Factor Authentication (MFA)	A001 (Public Articles Archive)	Reputation damage due to misinformation on the website.
R002	T002	Disgruntled Insider	Unauthorized deletion or alteration of articles.	Excessive Access Privileges	A001 (Public Articles Archive), A002 (Database)	Loss of trust and operational disruption due to altered or deleted critical content.
R003	T003	Phishing Campaigns	Credential theft via phishing emails.	Lack of MFA, Ineffective Awareness Training	A004 (Employee Credentials)	Compromise of employee accounts leading to further exploitation of sensitive systems.
R004	T004	Cybercriminals	Data exfiltration for financial gain.	Misconfigured Database Permissions	A002 (Database), A004 (Employee Credentials)	Financial losses and exposure of sensitive data due to unauthorized access.
R005	T005	Script Kiddies	Brute force attacks on CMS login credentials.	Lack of MFA	A001 (Public Articles Archive)	Unauthorized access to CMS; potential for limited data compromise or disruption.
R006	T006	Natural Disasters	Flooding damaging physical assets.	Weak Physical Security	A013 (Backup Devices), A003 (Financial Data)	Data loss and financial recovery challenges due to physical asset damage.
R007	T007	Hardware Failures	Backup device failure during recovery.	Limited Backup Testing	A013 (Backup Devices)	Inability to recover critical data after a system failure.
R008	T008	System Misconfiguration	Misconfigured CMS exposing sensitive data.	Misconfigured Database Permissions	A001 (Public Articles Archive), A002 (Database)	Unauthorized access to sensitive data due to poor configurations, leading to loss of trust and data breaches.
R009	T009	Software Bugs	CMS plugin errors disrupting publishing.	Software Bugs in CMS Plugins	A001 (Public Articles Archive)	Publishing process interruptions, reducing operational efficiency and credibility.

RISK ASSESSMENT – TVA SHEET – CNTD.

R010	T010	Third-Party Service Failures	Hosting outages or DNS disruptions.	Dependence on Third-Party Services	A007 (Flywheel Hosting)	Website unavailability, affecting trust and operational continuity.
R011	T011	Human Error	Accidental publication of sensitive data.	Lack of Logging and Monitoring	A002 (Database), A005 (Internal Policies)	Exposure of sensitive or inaccurate data, leading to operational and reputational damage.
R012	T012	Power Outages	Temporary unavailability of office systems.	Single Point of Failure in IT Resources	A011(Office Desktops)	Temporary loss of productivity and access to critical systems.
R013	T013	Insider Threats	Unauthorized use of retained access by an ex-Employee	Gain Privileged Access	A001 (Public Articles Archive), A002 (Database)	Misuse of access to compromise data integrity and confidentiality.
R014	T014	Cyberattacks	Disruption of publication systems.	Outdated CMS Software	A001 (Public Articles Archive)	Loss of availability and operational disruption due to system compromise.
R015	T015	Hardware Failure	Device failure causing data loss.	Limited Backup Testing	A013(Backup Devices), A011(Office Systems)	Data loss and operational inefficiencies due to hardware malfunctions.
R016	T016	Human Error	Publication of sensitive or incorrect data.	Lack of Logging and Monitoring	A002 (Database), A005 (Internal Policies)	Operational inefficiencies and loss of trust due to inadvertent publication of incorrect or sensitive content.

RISK ANALYSIS – RISK REGISTER

Risk ID	Threat Source	Threat Event	Vulnerability	Affected Asset(s)	Potential Impact	Likelihood	Impact	Risk Level	MITRE ATT&CK TTP
R001	Hacktivists	Website defacement to spread misinformation.	Lack of Multi-Factor Authentication (MFA)	A001 (Public Articles Archive)	Damage to reputation and trust.	Moderate	High	Moderate	T1190: Exploit Public-Facing Application
R002, R013	Disgruntled Insider	Unauthorized deletion or alteration of articles.	Excessive Access Privileges	A002 (Database)	Loss of trust and operational disruption.	Moderate	High	Moderate	T1078: Valid Accounts
R003	Phishing Campaigns	Credential theft via phishing emails.	Lack of MFA, Ineffective Awareness Training	A004 (Employee Credentials)	Compromise of sensitive employee credentials.	High	High	High	T1566: Phishing
R004	Cybercriminals	Data exfiltration for financial gain.	Misconfigured Database Permissions	A002 (Database), A004 (Employee Credentials)	Financial losses and data breaches.	High	High	High	T1020: Data Transfer to Cloud
R005	Script Kiddies	Brute force attacks on CMS login credentials.	Lack of MFA	A001 (Public Articles Archive)	Limited compromise of content.	Low	Low	Low	T1110: Brute Force
R006	Natural Disasters	Flooding damaging physical assets.	Weak Physical Security	Backup Devices, A003 (Financial Data)	Loss of critical assets and financial data.	Low	High	Moderate	T1580: Physical Destruction

RISK ANALYSIS – RISK REGISTER – CNTD.

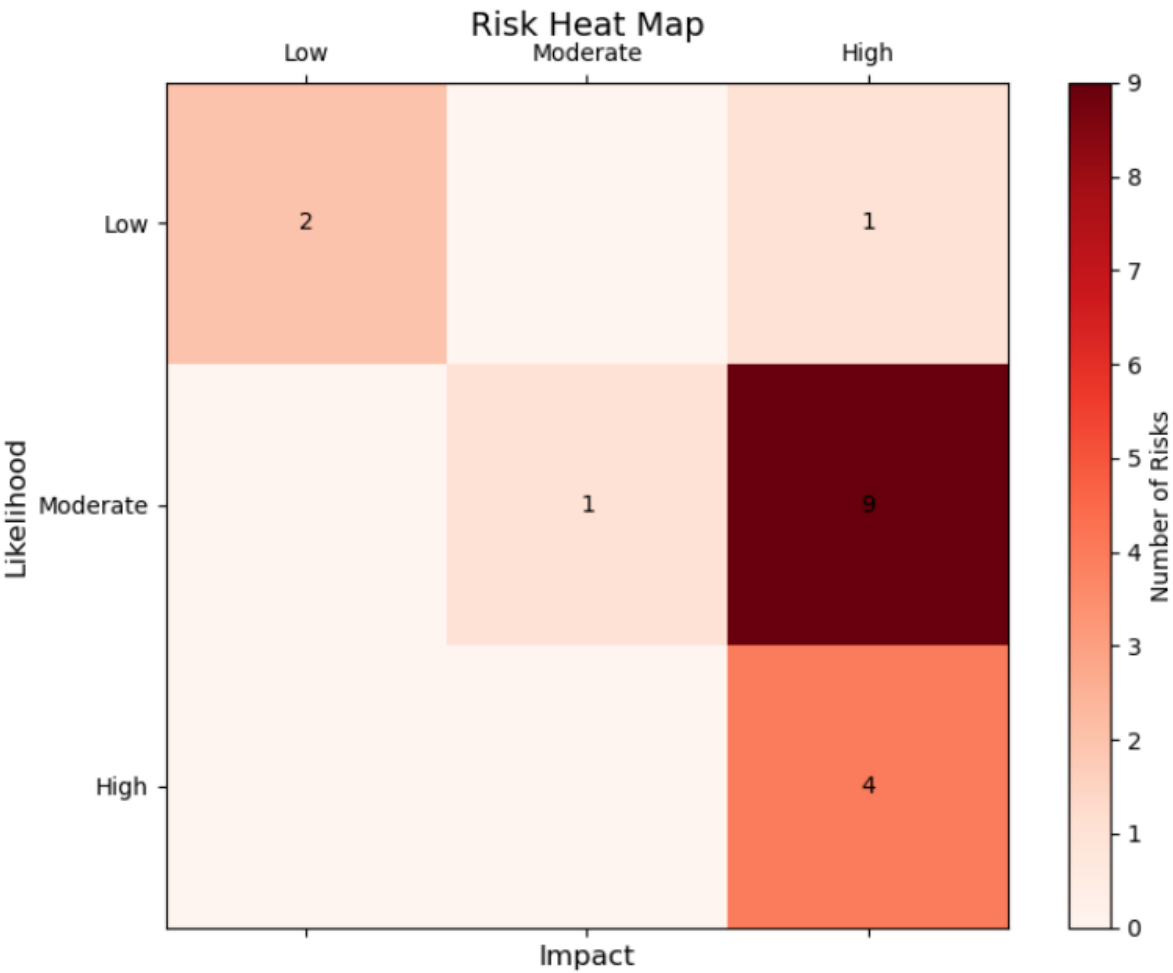
R007, R015	Hardware Failures	Backup device failure during recovery.	Limited Backup Testing	Backup Devices	Inability to recover critical data.	Moderate	High	Moderate	T1529: System Shutdown/Reboot
R008	System Misconfiguration	Misconfigured CMS exposing sensitive data.	Misconfigured Database Permissions	A001 (Public Articles Archive), A002 (Database)	Loss of sensitive data and availability.	High	High	High	T1068: Exploitation for Privilege Escalation
R009	Software Bugs	CMS plugin errors disrupting publishing.	Software Bugs in CMS Plugins	A001 (Public Articles Archive)	Disruption to publishing operations.	Moderate	Moderate	Moderate	T1203: Exploitation for Client Execution
R010	Third-Party Failures	Hosting outages or DNS disruptions.	Dependence on Third-Party Services	Flywheel Hosting, DNS	Website inaccessibility, affecting operations.	Moderate	High	Moderate	T1499: Endpoint Denial of Service
R011, R016	Human Error	Accidental publication of sensitive data.	Lack of Logging and Monitoring	A002 (Database), A005 (Internal Policies)	Exposure of sensitive or inaccurate data.	Moderate	High	Moderate	T1074: Data Staged
R012	Power Outages	Temporary unavailability of office systems.	Single Point of Failure in IT Resources	Office Desktops	Temporary loss of productivity.	Low	Low	Low	T1499: Endpoint Denial of Service
R014	Cyberattacks	Disruption of publication systems.	Outdated CMS Software	A001 (Public Articles Archive)	Loss of availability and operational disruption.	High	High	High	T1195: Supply Chain Compromise

MAIN RISKS

Heat Map for Risk Register:

Risk Level Matrix:

Risk Level	Risk IDs	Priority
High Risk	R003, R004, R008, R014	Immediate attention required.
Moderate Risk	R001, R002, R006, R007, R009, R010, R011, R013, R015, R016	Address after critical issues.
Low Risk	R005, R012	Monitor and reassess periodically.



Risk ID	Description	Justification
R003	Credential theft via phishing campaigns.	High likelihood and impact due to phishing prevalence, lack of MFA, and insufficient training.
R004	Data exfiltration for financial gain.	High risk due to misconfigured databases and potential for sensitive data loss.
R008	Misconfigured CMS exposing sensitive data.	High likelihood of privilege escalation, impacting both availability and confidentiality.
R014	Cyberattacks disrupting publication systems.	High likelihood of exploitation due to outdated CMS software, impacting critical operations.

RISK MITIGATION STRATEGIES

Threat Source	Risk ID	MITRE Mitigation Strategy and Preventative Measures	MITRE Detection Strategy
Hacktivists & Script Kiddies	R001, R005	Apply multi-factor authentication (M1032), secure configurations (M1054) Implement Web Application Firewall	Monitor web server logs for anomalous behavior (DS0009)
Disgruntled Insider	R002, R013	Limit access privileges (M1028), enforce account management policies (M1018)	Monitor access patterns for unusual activities (DS0017)
Phishing Campaigns	R003	conduct awareness training (M1017)	Analyze email content and user behavior for phishing signs (DS0029)
Cybercriminals	R004	Implement strong database access controls (M1021), encrypt data at rest (M1040)	Detect unusual data transfer activity (DS0002)
Natural Disasters	R006	Develop disaster recovery plans (M1057), implement physical security measures (M1053)	Monitor for environmental alerts and asset status (DS0036)
Hardware Failures	R007, R015	Regularly test and validate backups (M1053), use redundant systems (M1037).	Audit backup integrity and failure logs (DS0018)
System Misconfiguration	R008	Secure configuration management (M1038), harden CMS configurations (M1054).	Detect unusual privilege escalation attempts (DS0028).
Software Bugs	R009	Regularly patch and update plugins (M1051), conduct software testing (M1048)	Monitor plugin logs and crash reports (DS0014)
Third-Party Failures	R010	Use redundant service providers (M1037), ensure SLAs with hosting providers (M1056)	Monitor Flywheel availability metrics (DS0023)
Human Error	R011, R016	Implement data classification and monitoring (M1036), use access controls (M1021)	Detect unusual data access patterns or modifications (DS0002)
Power Outages	R012	Deploy UPS systems (M1053), ensure alternate IT resources are available (M1057)	Monitor system uptime and power anomalies (DS0034)
Cyberattacks	R014	Regularly update CMS software (M1051), conduct supply chain risk assessments (M1055)	Monitor software supply chain changes and CMS behavior (DS0009)
Hardware Failure	R015	Conduct regular hardware maintenance (M1033), test backups regularly (M1053)	Track hardware diagnostics and error logs (DS0018)

RISK MITIGATION STRATEGIES



Secure configuration



Account Management



Patching & Testing



Awareness Training



CMS Hardening



Access Control



Encrypt Data at Rest



System monitoring



Regular Updates CMS



Supply Chain Risk Assessment

SUGGESTED MITIGATION TIMELINE

IMMEDIATE SUGGESTIONS

- High Level Risks - MFA, Access Audits, Phishing training, system monitoring

3 TO 6 MONTHS

- Moderate and Low-Level Risks – Recovery plan, patching, testing

VALID FOR ONE YEAR

- Recommend review/verification of implementations at 6 months

THANK YOU

QUESTIONS ?

ORGANIZATIONAL RISKS

Risk ID	Risk Description	Threat Source	Vulnerability	Affected Asset(s)	Likelihood	Impact	Risk Level	Proposed Mitigation
RISK-L001	Legal action due to defamatory content in articles.	Legal Claims	Insufficient editorial oversight.	Published Content	Moderate	High (Integrity)	High	Establish an editorial review board to fact-check and approve articles, especially sensitive topics.
RISK-L002	Copyright infringement due to improper use of media assets.	Legal Claims	Improper sourcing of copyrighted material.	Published Articles, Media Assets	Moderate	Moderate (Integrity)	Moderate	Use licensed media or ensure proper attribution for images, videos, and other content.